

Elabore um resumo estruturado completo

Este resumo estruturado foi elaborado a partir do conteúdo da **Aula 03 – Conceitos de Tecnologia de Informação 1** (focada em **Segurança da Informação**).

1. Conceitos Básicos e Definições de Segurança da Informação

- **Definição:** Segurança da Informação é a proteção e salvaguarda das informações e sistemas organizacionais contra acesso, uso, divulgação, interrupção, modificação ou destruição não autorizados.
 - **Controles de Segurança:**
 - **Controles Físicos:** Barreiras físicas que impedem ou limitam o acesso direto aos dados ou à infraestrutura. *Exemplos:* portas, trancas, salas-cofre, geradores, câmeras, alarmes e catracas.
 - **Controles Lógicos (Técnicos):** Barreiras que controlam o acesso no ambiente digital por meio de softwares e hardwares. *Exemplos:* senhas, firewalls, listas de controle de acesso (ACLs), criptografia, biometria e sistemas IDS/IPS.
 - **Regra de Classificação:** O tipo de controle depende do **recurso protegido**, e não da tecnologia utilizada. Por exemplo, o uso de biometria para acessar uma sala física constitui um controle físico; o uso de biometria para autenticar em um sistema de computador constitui um controle lógico.
-

2. Terminologia Fundamental

- **Ativo:** Qualquer bem que tenha valor para a organização (ex.: dados, pessoas, sistemas, infraestrutura).
 - **Informação:** Ativo valioso de negócio que deve ser protegido.
 - **Agente:** Fonte geradora de um evento adverso sobre um ativo (ex.: hackers, funcionários, desastres naturais).
 - **Vulnerabilidade:** Fragilidade ou falha associada a um ativo.
 - **Ameaça:** Agente externo que explora uma vulnerabilidade para quebrar a segurança do ativo.
 - **Ataque:** Ação intencional de exploração de vulnerabilidade por uma ameaça para obter, alterar ou destruir dados sem autorização.
 - **Evento:** Ocorrência identificada em um sistema ou rede que indica uma possível violação de segurança ou falha.
-

3. Princípios e Atributos de Segurança da Informação

A. Tríade Fundamental (CID)

1. **Confidencialidade:** Garante que a informação não seja acessada ou revelada a indivíduos, entidades ou processos não autorizados.
2. **Integridade:** Garante a exatidão, fidedignidade e completeza da informação, assegurando que ela não seja alterada ou corrompida sem autorização.
3. **Disponibilidade:** Garante que a informação e os sistemas estejam acessíveis e utilizáveis sempre que demandados por usuários autorizados.

B. Princípios Adicionais

- **Autenticidade:** Garante a veracidade da identidade do emissor ou autor de uma informação/mensagem.
- **Irretratabilidade (Não-Repúdio):** Garante que o emissor de uma mensagem ou participante de uma transação não possa negar posteriormente a autoria da ação realizada.

C. Hexagrama Parkeriano

Proposto por Donn B. Parker, amplia os atributos de segurança para seis dimensões:

- **CID + Autenticidade.**
- **Posse ou Controle:** Refere-se a quem detém fisicamente/logicamente a informação (ex.: roubo de um dispositivo).
- **Utilidade:** Capacidade da informação de estar em formato útil e legível para a tomada de decisão.

4. Ataques ao Fluxo de Informações e Princípios Violados

Analisando a comunicação de dados, diferentes tipos de ataques comprometem princípios específicos:

- **Interrupção:** O fluxo de dados é cortado antes de chegar ao destino $\rightarrow$ Violado: **Disponibilidade**.
- **Interceptação:** Um terceiro não autorizado acessa o conteúdo da mensagem $\rightarrow$ Violado: **Confidencialidade**.
- **Modificação:** O conteúdo original é alterado antes de chegar ao destinatário $\rightarrow$ Violado: **Integridade**.
- **Fabricação:** Um terceiro insere dados falsos fingindo ser a fonte legítima $\rightarrow$ Violado: **Autenticidade**.

5. Criptologia e Criptografia

- **Criptologia:** Ciência subdividida em **Esteganografia** (ocultação de uma mensagem dentro de outro arquivo), **Criptografia** (transformação da mensagem em texto ininteligível) e **Criptoanálise** (técnicas para quebrar segredos criptográficos).
- **Fundamentos:** Opera por **Substituição** (troca de elementos) e **Transposição** (reorganização da ordem).

A. Criptografia Simétrica (Chave Secreta/Compartilhada)

- Utiliza a **mesma chave secreta** para encriptar e decriptar.
- **Características:** Alta velocidade de processamento e baixo custo computacional.
- **Desvantagem:** Dificuldade de compartilhamento seguro da chave entre as partes. O número de chaves necessárias cresce segundo a fórmula $\frac{n(n-1)}{2}$.
- **Garantias:** Prove por si só **Confidencialidade**. Se o texto em claro for enviado junto e a chave for estritamente secreta entre duas partes, pode indicar **Integridade e Autenticidade**, mas **não garante o não-repúdio**.
- **Algoritmos:** DES, 3DES, AES, IDEA, RC4, Blowfish e Cifragem de César.

B. Criptografia Assimétrica (Chave Pública)

- Utiliza um **par de chaves exclusivo**: uma **chave pública** (divulgada a todos) e uma **chave privada** (secreta e de uso pessoal).
- **Mecanismos de Uso:**
 - **Para garantir Confidencialidade:** O emissor encripta a mensagem com a **chave pública do destinatário**; apenas o destinatário consegue decriptar com sua **chave privada**.
 - **Para garantir Autenticidade e Assinatura Digital:** O emissor encripta (assina) com sua **chave privada**; qualquer pessoa pode verificar e decriptar com a **chave pública do emissor**.
- **Garantias:** Pode assegurar **Confidencialidade, Integridade, Autenticidade e Não-Repúdio**.
- **Características:** Requer gerenciamento de apenas $2n$ chaves. Contudo, é até 100 vezes mais lenta que a simétrica e exige chaves maiores para manter o mesmo nível de segurança.
- **Algoritmos:** RSA, DSA, ECDSA, ElGamal e Diffie-Hellman.

C. Criptografia Híbrida

- Combina os dois modelos: utiliza a **criptografia assimétrica** para negociar e trocar com segurança uma **chave simétrica de sessão**, e passa a usar a **criptografia simétrica** para a transmissão ágil dos dados volumosos.
- *Exemplo clássico:* Protocolos **SSL/TLS** (HTTPS).

D. Princípio de Kerckhoffs

- A segurança de um sistema criptográfico deve residir no **sigilo e tamanho da chave**, e na **força do algoritmo**, e nunca no segredo do funcionamento do algoritmo em si.
-

6. Controle de Acesso e Autenticação

A. Três Pilares do Acesso

1. **Identificação:** Processo pelo qual o usuário se apresenta ao sistema (ex.: login, e-mail, CPF).
2. **Autenticação:** Verificação se a identidade apresentada é verdadeira (ex.: senha, biometria).
3. **Autorização:** Definição dos privilégios e permissões de acesso do usuário dentro do sistema (ex.: permissão para ler ou excluir um arquivo).

B. Fatores de Autenticação

- **O que você sabe:** Senhas, PINs, perguntas secretas.
 - **O que você tem:** Tokens, smart cards, telefones celulares, crachás.
 - **O que você é:** Características biométricas (impressão digital, íris, voz, reconhecimento facial).
 - **Autenticação Forte / Multifator (MFA):** Exige a combinação de pelo menos **dois fatores de categorias distintas**.
-

7. Assinatura Digital e Função Hash

- **Função Hash (Resumo Criptográfico):** Algoritmo matemático de sentido único que transforma dados de qualquer tamanho em uma saída de tamanho fixo. Utilizado para garantir a **Integridade**. *Algoritmos:* MD5, SHA-1, SHA-256.
 - **Assinatura Digital:** Mecanismo que aplica a **criptografia assimétrica** sobre o hash de uma mensagem. O emissor calcula o hash do documento e o encripta com sua **chave privada**.
 - **Propriedades Garantidas: Integridade, Autenticidade e Não-Repúdio.** *A assinatura digital por si só não garante confidencialidade.*
-

8. Certificado Digital e ICP-Brasil

- **Certificado Digital:** Documento eletrônico (no padrão **X.509 v3**) assinado por uma Autoridade Certificadora que associa a identidade de uma pessoa/entidade a uma chave pública.
- **ICP-Brasil (Infraestrutura de Chave Pública Brasileira):** Estrutura hierárquica baseada no princípio da terceira parte confiável:
 - **Autoridade Certificadora Raiz (AC-Raiz):** Primeira autoridade da cadeia (gerida pelo ITI). Executa as normas do Comitê Gestor, emite/gerencia certificados das ACs de nível subsequente, emite a Lista de Certificados Revogados (LCR) e auditada a estrutura. Possui certificado autoassinado.
 - **Autoridades Certificadoras (ACs):** Entidades encarregadas de emitir, renovar, distribuir e revogar certificados digitais de usuários/entidades finais, além de publicar a LCR.

- **Autoridades de Registro (ARs):** Interface presencial/remota de atendimento ao usuário. Recebem, validam e encaminham solicitações de emissão ou revogação. **ARs não emitem certificados digitais.**
 - **Tipos e Categorias de Certificados:**
 - **Categoria A:** Certificados de Assinatura Digital (autenticação e assinatura).
 - **Categoria S:** Certificados de Sigilo (criptografia/confidencialidade).
 - **Modalidades de Armazenamento e Validades:**
 - **A1 / S1:** Gerado por software (instalado no HD/computador); validade máxima de **1 ano**.
 - **A2 / S2:** Gerado por software (em smart card ou token); validade máxima de **2 anos**.
 - **A3 / S3:** Gerado por hardware criptográfico inviolável (token USB ou smart card); validade máxima normativa de **5 anos**.
 - **A4 / S4:** Gerado por hardware de alta segurança (HSM); chave mínima de 2048 bits (suporta 4096 bits); validade máxima de **6 anos**.
-

9. Classificação de Dados

Processo organizacional de categorizar as informações com base no nível de sensibilidade e impacto de vazamento:

- **Público:** Acesso irrestrito; divulgação não causa danos.
 - **Interno:** Uso exclusivo da organização; vazamento gera impacto operacional moderado.
 - **Confidencial:** Dados sensíveis (ex.: dados pessoais, contratos, relatórios financeiros); vazamento gera prejuízos graves.
 - **Restrito:** Dados altamente estratégicos e críticos; acesso extremamente limitado.
-

💡 *Se desejar aprofundar em algum desses tópicos (como resolução de questões de bancas como CEBRASPE e FGV ou criação de mapas mentais sobre criptografia assimétrica), é só me avisar!*